

11. preza

- sigurnost je sposobnost mreža/sustava/usluga/aplikacija da se suprotstave neočekivanim slučajnim događajima i zlonamjernim aktivnostima
- sigurnosni zahtjevi:
 - o povjerljivost - poruke trebaju biti razumljive samo pošiljatelju i primatelju
 - o cjelovitost - jamstvo da su poruke poslane i primljene u izvornom obliku
 - o raspoloživost - info moraju biti raspoložive nebitno šta se događa
 - o autentičnost - potvrda identiteta korisnika
 - o neporecivost - sudionici ne mogu poreći da su nešto poslali
- dva preduvjeta za incident su ranjivost i prijetnja
- sigurnosne prijetnje:
 - o presretanje
 - o prisluškivanje (može biti na komunikacijskom vodovodu)
 - o prekidanje
 - o uskraćivanje usluge
 - o promjena (man in the middle)
 - o fabrikacija - ubacivanje zlonamjerne informacije
 - o ponavljanje - ubacivanje informacije preuzete prestretanjem
 - o lažno predstavljanje
- većina protokola koje koristimo (npr. ARP, Ethernet, TCP, UDP, IP, itd.) su ranjivi jer nemaju mehanizme koji bi osiguravali sigurnost
- kako postizemo sigurnost?

Kriptografija

- osnovni algoritmi su simetrično i asimetrično šifriranje i dešifriranje (bit će objašnjeno koja je razlika) i izračunavanje sažetka
- šifriranjem pretvaramo čisti tekst (plaintext, P) u šifrirani tekst (ciphertext, C)
- simetrični algoritmi:
 - o koristimo isti ključ za šifriranje i dešifriranje
 - o tajnost se temelji na tajnosti ključa, najčešće dulji ključ znači veću zaštitu
 - o imamo blok orijentirane (duljina ključa je fiksna) i bit/bajt orijentirane algoritme (duljina ključa je duljina poruke)
 - o algoritam DES:
 - blok orijentiran, blok je veličine 64 bita, a ključ 56 bita
 - za moderne standarde nesiguran, lako je brute forceom otkriti ključ
 - o algoritam AES:
 - blok orijentiran, blok je veličine 128 bita, a ključ 128/192/256 bita
 - o problemi simetrične kriptografije:
 - često količina podataka nije višekratnik veličine bloka, na ovo se mora paziti kako ne bi napadaču otkrili dio plaintexta ili ključa
 - problemi sa odabirom i distribucijom ključa
- asimetrični algoritmi:
 - o opći nedostatak je da su između 100 i 1000 puta sporiji od simetričnih
 - o public key cryptography
 - svaki sudionik ima javni (E) i privatni ključ (D), javni ključ se objavljuje, a privatni čuvamo na sigurnom
 - kriptiranje i dekriptiranje s različitim ključevima, za kriptiranje koristimo javni, a za dekriptiranje privatni
 - jako je teško iz E dobiti D, a E se ne može probiti
 - o algoritam RSA:
 - algoritam temeljen na faktorizaciji velikih brojeva (većih od 10^{100})
 - sigurnost se temelji na nemogućem dugom vremenu brute forcea
- u praksi: za razmjenu ključeva koriste se asimetrični algoritmi, a za samo šifriranje simetrični
- sažetak poruke (MD):
 - o iz proizvoljno dugog teksta generira niz bita fiksne duljine
 - o lako izračunati MD(P), nemoguće izračunati P iz MD(P)
 - o primjeri: sha2, sha3
- primjena sažetka - kad skidamo neku datoteku skinemo i njen izračunati sažetak, kasnije sami izračunamo sažetak i ako su isti onda datoteka nije mijenjana (slična šema ko zaštitne sume)
- digitalni potpis:
 - o način da primatelj može provjeriti identitet pošiljatelja
 - o za potpisivanje se koristi kriptografiju javnog ključa (mora vrijediti uvjet $E(D(P)) = P$)
 - o generiranje i provjera potpisa:
 - pošiljatelj izračunava MD(P)
 - MD(P) kriptira svojim tajnim ključem D
 - primatelj dekriptira koristeći javni ključ od pošiljatelja: $E(D(MD(P))) = MD(P)$
 - izračunava MD(P')
 - uspoređuje MD(P) s MD(P')

Postupak kriptiranja i dekriptiranja:

1. svaki sudionik, A i B, objavljuje svoj javni ključ, E_A i E_B :

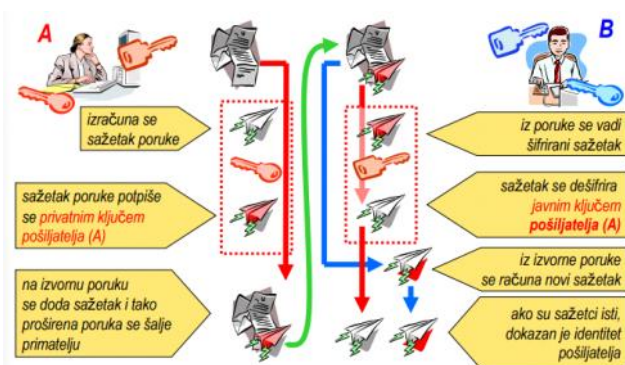
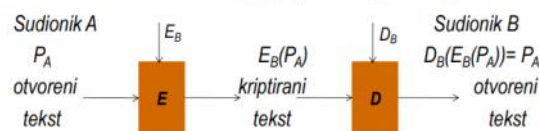
$$A \sim E_A, B \sim E_B$$

2. kriptiranje: $A \rightarrow B: E_B(P_A)$ javni ključ E_B

$B \rightarrow A: E_A(P_B)$ javni ključ E_A

3. dekriptiranje: $B: D_B(E_B(P_A)) = P_A$ privatni ključ D_B

$A: D_A(E_A(P_B)) = P_B$ privatni ključ D_A



- problem distribucije javnih ključeva: kako znamo da nam neko nije podmetnuo svoj javni ključ?
- rješenje: postoji organizacija kojoj svi vjeruju, certifikacijsko tijelo koje izdaje certifikate korisnika
- TLS - transport layer security, koristi TCP za prijenos, pruža zaštitu od prisluškivanja, lažiranja, ponavljanja, izmjene, fabrikacije; koristi certifikate za autentifikaciju
- S/MIME - sigurnost emaila, svaki korisnik ima privatni ključ i certifikat
- PGP - sigurnost emaila, temelji se na međusobnom dijeljenju javnih ključeva bez centraliziranog nadzora
- vatrozid - radi na mrežnom sloju i nadzire promet, zadaća mu je sigurnost krajnjih sustava i mreža, osnovne akcije su ODBACI i PROPUSTI
 - o vrste:
 - stateless
 - statefull

